

# Cybersecurity Risk Assessment Framework

for Small and Medium Enterprises

---

## Overview

Most small businesses think they are too small to be targeted by hackers. That is exactly why they get targeted. Attackers look for easy wins, and a business without a proper security setup is exactly that. This project builds a straightforward framework that helps small and medium businesses figure out where they are vulnerable, how serious each risk actually is, and what they can do about it without needing a large IT team or budget.

## Why This Matters

Over 43% of all cyberattacks target small businesses. Of those hit by a serious breach, around 60% shut down within six months — not always because of the breach itself, but because of the downtime, recovery costs, and lost customer trust that follow. The problem is not that small businesses are unaware of the risk. It is that they have no clear starting point. This framework gives them one.

---

## Common Threats Facing SMEs

### Phishing and Email Fraud

Someone in the company gets an email that looks like it came from their bank, their boss, or their IT team. They click a link, enter their password, and the attacker now has access. This is how most breaches start. It is cheap to pull off and works surprisingly often because the emails have become very convincing.

### Ransomware

Ransomware locks up all the files on a computer or server and demands payment to unlock them. For a small business with no backups, this can mean days or weeks of downtime. Some attackers also steal the data before encrypting it and threaten to publish it unless they get paid.

### Insider Threats

Not every threat comes from outside. A disgruntled employee, a careless one, or a former staff member whose account was never deactivated can cause just as much damage. Small businesses often skip proper access controls because it feels like extra admin work — until something goes wrong.

### Outdated Software

Running software that is no longer receiving security updates is like leaving a door unlocked. Attackers actively scan for systems running known vulnerable versions and exploit them with automated tools. Patching is one of the simplest and most effective things a business can do.

### Weak Passwords and No MFA

Password reuse is everywhere. When one website gets breached, attackers take those username and password combinations and try them on hundreds of other sites. Without multi-factor authentication, a stolen password is all they need.

---

## The Risk Assessment Model

The framework is built around the NIST Cybersecurity Framework, adapted to work for businesses that do not have a dedicated security team. It breaks down into six practical steps:

- Govern** — Set a clear security policy, decide who is responsible, and define how much risk the business is willing to accept.
  - Identify** — Make a list of everything that matters — computers, software, data, and who has access to what.
  - Protect** — Put controls in place. This means things like strong passwords, MFA, employee training, and keeping software updated.
  - Detect** — Set up basic monitoring so that if something goes wrong, the business knows about it quickly rather than weeks later.
  - Respond** — Have a written plan for what to do when an incident happens. Who do you call? What do you shut down first?
  - Recover** — Back up data regularly and actually test that the backups work. Know how long recovery will take.
- 

## How Risks Are Scored

Every identified threat is given a score based on three factors: how likely it is to happen, how bad it would be if it did, and how exposed the business currently is. Multiplying these together gives a number between 0 and 25 that makes it easy to compare risks and decide what to fix first.

*Risk Score = Likelihood (1–5) × Impact (1–5) × Exposure Factor (0.1–1.0)*

| Threat                  | Score | Level    | What to Do            |
|-------------------------|-------|----------|-----------------------|
| Phishing / Email Fraud  | 22.5  | Critical | Fix within 48 hours   |
| Ransomware              | 18.0  | High     | Fix within 2 weeks    |
| Unpatched Software      | 12.8  | Medium   | Fix within 60 days    |
| Weak Passwords / No MFA | 11.2  | Medium   | Fix within 60 days    |
| Insider Threat          | 8.4   | Medium   | Next review cycle     |
| Supply Chain Attack     | 6.0   | Low      | Scheduled maintenance |

---

## Mitigation Strategies

Good security does not require expensive tools. Most of the highest-impact steps are either free or very low cost:

### Turn on MFA everywhere

Multi-factor authentication is the single most effective thing a business can do. Even if an attacker steals a password, they cannot log in without the second factor.

### Train staff regularly

People are the most targeted part of any organization. Short, practical training sessions — and regular phishing simulations — build habits that technical tools cannot replace.

### Keep software updated

Set up automatic updates wherever possible. Critical patches should be applied within 72 hours of release.

### Back up data and test it

Follow the 3-2-1 rule: three copies of data, on two different types of media, with one copy stored offsite. Test that backups can actually be restored at least once a quarter.

### Write an incident response plan

A one-page document answering who to call, what to shut down, and how to communicate is worth more than any security tool when something actually goes wrong.

### Review access regularly

Remove access for anyone who no longer needs it. Check the full list at least twice a year.

---

## Case Studies

### E-Commerce Business — 25 employees

The biggest risk here was phishing. Three employees clicked links in a test phishing email during the initial assessment. Customer payment data was also being backed up locally without encryption. After running phishing simulation training for three months, the click rate dropped by 78%. Backups were moved to encrypted cloud storage, and the business passed its PCI-DSS assessment within 60 days.

### Healthcare Clinic — 40 employees

The clinic was still running patient records software on Windows 7, which stopped receiving security updates years ago. Their last successful backup restore test was 18 months prior. After migrating to a cloud-based system and setting up automated daily backups with weekly restore tests, recovery time dropped from an estimated four days to under six hours.

### Accounting Firm — 15 employees

The firm was approving wire transfers based on email requests alone — a setup that is trivially easy for attackers to exploit. Remote desktop was also directly accessible from the internet. Adding a second verification step for any transfer, moving remote access behind a VPN, and deploying MFA eliminated

both risks completely.

---

## **Key Takeaways**

- Phishing is the starting point for most attacks. Training and MFA together stop the majority of them.
- A numerical risk score takes the guesswork out of deciding what to fix first.
- All three case study businesses made significant improvements within 30 to 90 days.
- Security does not need to be expensive. The highest-impact steps are mostly free.
- Compliance — PCI-DSS, HIPAA — tends to follow naturally from applying the framework properly.